



University of Bahrain
College of Information Technology
Department of Information Systems
ITCY460 - Security Risk Assessment and Countermeasures

Group Project: Risk Management Plan Meridian FinTech Solutions

Second Semester 2025/2026

Aljazi Ali Almujaaddam - 202202227
Dana Hussain Alhayki - 202204341
Noora Abdulrahman Bumjaaid - 202203245
Nada Abdulaziz Yahya - 202203864
Maram Abdulqawi Ghaleb - 202305067

Table of Contents:

Table of Contents:	2
1. Executive summary	4
3. Organization overview	5
4. Scope and boundaries	5
4.1 Scope	5
4.2 Boundaries	6
5. Compliance/ regulation	6
6. Roles and responsibilities	7
7. Risk management method	8
7.1 Risk Assessment Methodology	8
7.2 Likelihood Scale	8
7.3 Impact Scale	9
7.4 Risk Matrix/Risk Rating	9
7.5 Risk Treatment Strategy Selection	9
7.6 Ongoing Risk Management	10
8. Assets identification	10
9. Threat and vulnerability	11
10. Risk assessment	11
10.1 Risk Assessment Table	11
10.2 Risk Analysis Summary	12
10.3 Risk Prioritization	12
11. Risk mitigation	13
11.1 Risk Mitigation Table	13
11.2 Mitigation Strategy Overview	13
11.3 Residual Risk	13
11.4 Risk Treatment Approach	14
12. Cost-benefit analysis	14
12.1 Estimate of Losses Resulting from Security Incidents Absent Control Measures	14

12.2 Cost-Benefit Evaluation	15
12.3 Analysis Summary.....	15
12.4 Conclusion of CBA	15
13. Implement schedule	16
14. Business Impact Analysis	16
14.1 Critical Business Functions	16
14.2 Critical Resources.....	17
14.3 Potential Impacts from Disruptions.....	17
14.4 Recovery Objectives.....	17
14.5 BIA Summary.....	17
15. Business continuity plan (BCP)	18
15.1 Continuity Strategy.....	18
15.2 Backups and Data Recovery.....	18
15.3 Incident Response and Recovery.....	18
15.4 Communication Plan	19
15.5 BCP Roles and Responsibilities	19
15.6 BCP Testing and Maintenance	19
16. Monitoring and review	19
16.1. Continuous Monitoring	20
16.2. Periodic Review and reassessment of Risks.....	20
16.3. Audit and Compliance Review	20
16.4. Plan Maintenance/Updates	20
16.5. Monitoring Summary	21
17. Conclusion	21
18. Appendices.....	22

1. Executive summary

Meridian FinTech Solutions is a fast-growing financial technology firm based on cloud computing. It depends on Amazon Web Services and Google Cloud for managing its main financial services. These services include Pay-API, Fraud-Shield, Currency-X, Wallet-Link, and Fin-Report platforms responsible for providing payment processing, fraud detection, currency exchange, wallet management, and regulation reporting services, respectively. However, due to sensitive information involved in these processes, there are many risks associated with it. This report summarizes the risks identified by the risk management plan, risk assessment, risk mitigation plan, Business Impact Analysis, and Business Continuity Plan, and proposes measures for their reduction. The main risks associated with Meridian's cloud services include hard-coded API keys, insider threat, Business Email Compromise, weakness in Bring Your Own Device security policies, shadow IT communications risks, risks of cloud misconfigurations, and a lack of centralized SIEM management system. To mitigate these risks, various administrative, technical, and physical control measures need to be implemented. The proposed recommendations include a more secure bring your own device policy, secure coding procedures, API key rotations, Identity and Access Management enforcement, centralized SIEM management, email phishing training, multi-factor authentication and management, mobile device management, and physical security.

2. Introduction

Meridian FinTech Solutions is a rapidly expanding global financial technology firm that offers cloud computing services for payment processing and financial reporting. The firm operates in an extremely competitive and volatile industry that greatly depends on technology and cloud computing to offer its services. Given the amount of sensitive financial information and customer information processed by Meridian FinTech Solutions, the firm is exposed to high levels of cybersecurity risk and operational risk. These risks could arise from either internal or external factors, including cybercrime, phishing attacks,

insider risks, and vulnerabilities in the system. As such, the implementation of a Risk Management Plan is crucial in identifying, assessing, and mitigating these risks.

3. Organization overview

Meridian FinTech Solutions is an international fintech firm providing cloud computing services to its customers worldwide. Meridian has different branches in various regions of the world, such as San Francisco, London, and Tokyo. The firm serves thousands of customers using its cloud computing solutions. The revenue models of the firm involve transaction fees and subscription fees charged from its customers. Millions of transactions occur on a daily basis in the cloud environment. Some of the major services offered by the firm are Pay-API (payment processing solution), Fraud-Shield (fraud detection), Currency-X (currency conversion), Wallet-Link (wallet integration), and Fin-Report (reporting). Cloud computing solutions offered by the firm use Amazon Web Services and are supported by Google Cloud Platform. Despite enjoying scalability and flexibility due to the cloud environment, the firm is exposed to several cyber threats. Despite adopting all necessary measures and security precautions to safeguard its cloud environment, the firm remains exposed to various cyber threats due to personal devices (bring your own device) and decentralization of the communication environment.

4. Scope and boundaries

4.1 Scope

This document addresses the key systems, services, and processes that comprise Meridian FinTech Solutions' cloud-based financial operations. This includes the production environment on AWS Availability Zones and the Google Cloud Platform failover environment. Additionally, it includes the key platforms owned by Meridian, including Pay-API, Fraud-Shield, Currency-X, Wallet-Link, Fin-Report, and the Golden Record database, which supports Meridian's transactions, fraud protection, reporting capabilities, and customer information processing. The plan also covers internal risks associated with the employee

access environment. For instance, the company-issued MacBooks and Bring Your Own Device (BYOD) mobile devices will be covered in the plan. Some other internal risks include those associated with Shadow IT, hard-coded API keys, poor BYOD management, phishing, Business Email Compromise (BEC), cloud configuration errors, and lack of centralized Security Information and Event Management (SIEM). These risks affect confidentiality, integrity, availability, and business continuity of the organization. All these risks were identified through a risk assessment and mitigation process. Business Impact Analysis and Business Continuity Planning for the cloud data center environment also fall under the scope of the risk management plan.

4.2 Boundaries

This risk management plan applies only to systems, assets, and operations under direct control and management of Meridian FinTech Solutions. Third-party retailer systems connected via Pay-API and third-party banking networks interfaced with Currency-X are excluded, as they are not under the management of external organizations. Also excluded are customer-owned devices accessing the Wallet-Link application, as Meridian cannot exert full control and security over these. But risks arising from the utilization of unauthorized communication platforms and unmanaged BYODs by Meridian employees will be covered since these affect Meridian's security environment. The risk management plan shall not cover the actual code writing, system configuration details, or technical design specifications for the implementation.

5. Compliance/ regulation

Several regulatory bodies should be followed by Meridian FinTech Solutions because the organization processes financial transactions and stores user information in different countries. Such standards are necessary to preserve user information and keep operations safe. First, PCI DSS should be taken into account because Meridian uses Pay-API and processes user payments via the Pay-API platform. PCI DSS makes sure that cardholder information is protected properly. GDPR is another regulatory body that

Meridian needs to follow because the organization processes user data globally. In particular, Meridian has its office in London, and, therefore, user information from the European Union must be managed and protected properly. Next, AML standards must be followed because there is a need to manage financial transactions via the Fin-Report solution. ISO 27001 regulation is followed to ensure that Meridian has a management system that allows the company to provide adequate protection of user information and data stored in the cloud. Also, NIST SP 800-30 can be used to conduct risk assessment and analyze potential risks and threats to information security. Therefore, it is vital to follow all regulatory requirements to maintain information security and avoid any penalties from authorities.

6. Roles and responsibilities

The effective execution of the final Risk Management Plan would require the proper assignment of duties within Meridian FinTech Solutions. **Senior Management:** Endorses the risk management approach, allocates resources, evaluates risk management decisions, and promotes business continuity and recovery objectives. **Risk Management / Project Management Team:** Synchronizes the risk management process, makes sure the assessment and mitigation efforts adhere to the project's objectives, and communicates results to senior management. **IT Operations Team:** Provides support for AWS and Google Cloud services during cloud outages. This team manages all activities involving failover management and platform recovery. **Information Security Team:** Identifies technical risks, evaluates threats, measures security controls, and helps implement SIEM, IAM, MFA, API Security, and endpoint security solutions. **Risk and Compliance Team:** Verifies the plan meets regulatory requirements, including PCI DSS, GDPR, anti-money laundering regulations, ISO 27001, and NIST Special Publication 800-30, among others that had been previously established as pertinent to Meridian's operations. **Department Managers:** Collaborate with employees for risk assessment, risk mitigation, and continuity planning. In addition, they assist in communicating policies and reporting incidents that impact their departments. **End Users/Employees:**

Adhere to security policies, utilize authorized communication methods, adhere to BYOD policies, take required training, and report any unusual behavior or interruption of services. **Third-Party Cloud Providers:** Assist in providing cloud infrastructure for Meridian using AWS and GCP, although they do not have any obligations regarding Meridian's risk management processes and continuity plans.

7. Risk management method

Meridian FinTech Solutions uses a well-defined risk management process. The risk management process is designed to provide systematic identification, evaluation, and mitigation of all risks that could adversely affect the operation of the company. Meridian FinTech Solutions' risk management process is developed according to widely accepted standards in the field (i.e., NIST Risk Management Framework, NIST SP 800-30).

7.1 Risk Assessment Methodology

This plan utilizes a Qualitative Risk Assessment Methodology. A qualitative risk assessment methodology involves assessing risks using descriptive scales versus numeric values. This method is used when there is limited availability of accurate financial information. Risks are evaluated by **assessing two primary elements:** **Probability/likelihood of occurrence:** The likelihood that an identified threat will exploit a vulnerability. **Potential impact/consequence:** The amount of damage or disruption caused to the company's operations because of the occurrence of a risk event.

7.2 Likelihood Scale

The likelihood of a risk occurring is categorized as follows:

Table 7.2: Risk Probability Categorization

Level	Description
High	The risk is expected to occur frequently or has occurred multiple times in the past
Medium	The risk may occur occasionally under certain conditions

Low	The risk is unlikely to occur but is still possible
------------	---

7.3 Impact Scale

The impact of a risk is evaluated based on its potential effect on business operations:

Table 7.3: Potential Impact of Risks on Business Activities

Level	Description
High	Severe impact on business operations, significant financial loss, or reputational damage
Medium	Moderate disruption with manageable financial or operational impact
Low	Minimal impact with little or no disruption to operations

7.4 Risk Matrix/Risk Rating

A risk matrix is a tool used to evaluate the total risk by evaluating the relationship between the likelihood and potential impact of a particular risk. Based upon the position in the risk matrix, **risks can be classified into one of three categories: High-risk (Red):** Require immediate action and mitigation. **Medium-Risk (Yellow):** Planned mitigation and regular monitoring required. **Low-Risk (Green):** Accepted risk with low levels of monitoring. The classification of risk is determined by identifying the intersection of the likelihood and potential impact. Those risks that are considered High-Likelihood/High-Impact will receive priority consideration for mitigation.

7.5 Risk Treatment Strategy Selection

Once risks have been assessed and their relative importance determined, an appropriate treatment strategy should be selected. **There are four basic strategies for treating identified risks:** **Risk Avoidance:** Remove or eliminate the activity(s) that introduce(s) the risk. **Risk Mitigation:** Implement controls to reduce either the likelihood or impact of the risk. **Risk Transference:** Transfer the risk to a third-party entity (e.g., insurance policy, outsourced service provider). **Risk Acceptance:** If, after conducting a

thorough analysis, the risks have been deemed acceptable, then they can be retained by accepting them as part of your overall risk profile.

7.6 Ongoing Risk Management

The organization will use the four general approaches to manage **its identified risks by**: 1. Mitigating those risks when it can through the application of control measures (e.g., SIEM, MDM). 2. Avoiding all possible risky behavior (e.g., not using a hard-coded key for access). 3. Transferring those risks that cannot be mitigated or avoided to third-party entities or insuring against them. 4. Accepting as acceptable those risks which represent very low levels of risk and would have no significant impact on operational effectiveness.

8. Assets identification

Meridian FinTech Solutions' assets can be categorized into six categories: information, systems, infrastructure, hardware, personnel, and intangibles. The organization's information assets include customer financial data, transactional history, Meridian's Golden Record Database, payment processing history, and regulatory reporting, such as Anti-Money Laundering (AML) filings. The organization's system/application assets consist of its core platform applications, including Pay-API for payment processing, Fraud-Shield for fraud detection, Currency-X for cross-border currency exchange, Wallet-Link for integrating mobile wallets into the platform, and Fin-Report for automating compliance reporting. Meridian's infrastructure is completely cloud-based and relies solely on Amazon Web Services (AWS) for production, Google Cloud Platform (GP) for disaster recovery, and all related cloud services (compute, network, etc.) are provided and managed by third-party vendors. Meridian's hardware/endpoint assets include encrypted Apple MacBook computers used by employees, personally owned Bring Your Own Device (BYOD) smartphones/tablets used by employees, and remote access software used by employees. Personnel assets consist of DevOps engineers and IT/Security Teams responsible for maintaining operational security, Finance Staff who manage the organization's finances and employee base, and all other employees that

interact with Meridian's systems. Lastly, Meridian's intangible assets include its reputation, customer trust, Service Level Agreement (SLA) commitments, proprietary algorithm(s), and client relationships, which are necessary for maintaining business continuity and driving future growth.

9. Threat and vulnerability

Meridian is at threat from a variety of potential sources. Insider Risk - The terminated employee who has used hard-coded API Keys to exploit them. Cybercrime/Ransomware/Phishing etc. - The threat posed by BEC attacks via Finance Staff and those aimed at its cloud-based infrastructure, APIs, and Applications. Service outage risks arising as a result of reliance on Amazon Web Services (AWS) and Google Cloud Platform (GCP). Sensitive Customer and Financial Data breach if unauthorized access occurs. Employee exposure to Social Engineering techniques. Non-compliance with PCI DSS, GDPR, and/or AML regulations will have financial consequences for Meridian. Hardcoded Credentials, Absence of a centralized security information event management (SIEM) system for monitoring AWS/GCP; Shadow IT usage via Personal Messaging Apps. Poorly controlled Bring Your Own Device (BYOD), Inadequate Log Correlation; Limited Access Control Post Termination; Limited Anti-Phishing measures and limited Email Security controls. These all combine to illustrate the ways that an attacker could take advantage of weaknesses. Therefore, it is important for Meridian to identify its most critical areas of weakness and apply appropriate risk prioritization and mitigation strategies to create business resilience.

10. Risk assessment

10.1 Risk Assessment Table

A Qualitative Risk Assessment was performed to identify and assess the major risks facing Meridian FinTech Solutions' vital assets. As shown in Appendix A, each risk will be assessed by the probability that it may occur, and the potential impact on the company's ability to operate, to categorize as either high, medium or low risk. There are many significant risks identified, including risks associated with

unauthorized access, cyber-attack on the company's cloud-based financial systems, and/or compromising customer data. These risks need to have prompt action taken to mitigate them. As such, this assessment will allow Meridian FinTech Solutions to make informed decisions regarding how to prioritize the treatment of these risks and efficiently utilize limited resources to protect its cloud-based computing environment, financial processing systems, and customer confidential information.

10.2 Risk Analysis Summary

High-risk items: The majority of the risk items assessed were categorized at the high-risk level; specifically, those regarding unauthorized access, cloud security, and financial fraud. All three categories contain risks with a significant chance of occurring and would have a substantial negative effect on Meridian's business if they occurred. Therefore, these are the highest priority risks to mitigate.

Top risks: The top risk items include. 1- Unauthorized access due to hard-coded API keys. 2. Business e-mail compromise (BEC). 3. Lack of centralized monitoring (SIEM). 4. Cloud-related security issues.

All these risks pose threats to the confidentiality, integrity, and availability (CIA) of Meridian's systems and data.

10.3 Risk Prioritization

Risk is assessed by the potential for it to happen (likelihood) and what will be lost if it does occur (impact). Based upon these two factors, each risk is placed into a priority category, with the highest being Critical. A critical has both high likelihood and high impact. The next priority category is High. For this category, there is still a need for an immediate mitigation of the risk; however, it can wait until the end of the quarter or longer before a solution is implemented. Medium is used when the risk needs to continue to be monitored. If at some point the monitoring shows that the risk is no longer relevant to the organization, then it should be removed from the list. This way, all the time and money spent on mitigating one risk can now be focused on another.

11. Risk mitigation

11.1 Risk Mitigation Table

This Risk Mitigation Plan will provide a comprehensive set of controls and corrective actions to lower the probability and potential impact of the risks we have identified. Shown in Appendix B, recommended measures for this plan were established using recognized “best in class” standards from our industry, as well as specific to Meridian FinTech Solutions' cloud-based environment and operations. In order to prioritize the most significant risks we have identified, the plan assigns responsibilities, defines timeframes for implementation, and estimates costs associated with each control measure so that they can be executed in a practical manner. Ultimately, through the application of these controls, we aim to enhance our overall level of security, improve the resiliency of our systems, and ultimately reduce the residual risk to an acceptable level.

11.2 Mitigation Strategy Overview

The mitigation strategies will attempt to strengthen security controls, enhance the ability to monitor the system, and reduce risk related to humans. Some of these **key priorities are:** 1-Reduce/eliminate critical vulnerability of hard-coded credentials, 2- Increase ability to detect potential breaches via SIEM (centralized monitoring), 3- Decrease risk from social engineering by educating employees/training, 4- Establish better control over all devices used by employees in order to maintain communication, 5- Ensure that systems remain available through cloud redundancy

11.3 Residual Risk

Even after the recommended controls are implemented in a manner consistent with industry standards, there will be an element of risk that remains. That type of remaining risk is known as residual risk. Meridian FinTech Solutions will continue to monitor those risks so that they stay at reasonable levels by making continuous enhancements to our security and by periodically assessing them.

11.4 Risk Treatment Approach

The organization will use the four general approaches to manage **its identified risks** by:

1. Mitigating those risks when it can through the application of control measures (e.g., SIEM, MDM). 2. Avoiding all possible risky behavior (e.g., not using a hard-coded key for access). 3. Transferring those risks that cannot be mitigated or avoided to third-party entities or insuring against them. 4. Accepting as acceptable those risks which represent very low levels of risk and would have no significant impact on operational effectiveness. These structured methods will provide an effective way to manage the organization's identified risks while aligning with the overall organizational objectives.

12. Cost-benefit analysis

Cost-Benefit analysis (CBA) is an analytical methodology used by organizations to evaluate if specific security controls should be implemented based upon the comparison of the costs associated with implementing those security controls to the economic losses prevented from using those security controls. Clearly, given that Meridian FinTech Solutions produces revenues of about \$1.5 million per month, Meridian FinTech Solutions' ability to generate income will suffer substantially as a result of both temporary service interruptions and/or security breaches. All of the cost and loss estimates contained within this document are approximate. All cost and loss estimates developed for purposes of education only; they represent the cost and loss estimates currently associated with Meridian FinTech Solution's current revenue model and industry standards for service outages/losses and security breach-related economic impacts.

12.1 Estimate of Losses Resulting from Security Incidents

Absent Control Measures

Estimated costs and losses resulting from security incidents absent control **measures include:** 1-**Business E-Mail Compromise (BEC):** \$500,000 - \$1,000,000 Per Incident 2- **Data Breach (Customer Financial Data):** Greater Than \$1,000,000 Including Fines, Legal Costs And Reputational Damage 3- **Cloud Service**

Outage: Approximately \$20,000-\$50,000 Per Hour Of Downtime Based On Revenue Estimate 4-
Unauthorized Access To APIs Through Unauthorized Means: Greater Than \$500,000 Due To Fraud
Or System Compromise

12.2 Cost-Benefit Evaluation

The cost/benefit assessment proves that the suggested safety measures have a significant monetary and operational value. According to the table in Appendix C presented, the probable expense for the implementation of security measures (such as SIEM, API Key Management, and Cloud Failover) will be significantly less than the potential loss they could help avoid (including data breach, fraud incident; Service Downtime). The evaluation shows that investment in the safety measures described above is justified and important to eliminate high-impact risk and protect the Organization's operation and income.

12.3 Analysis Summary

The analysis indicates that the total cost of implementing the proposed security controls will be significantly less than the potential costs of losses resulting from security incidents or service disruptions. For instance, implementing a SIEM system costing approximately \$150,000 may prevent losses totaling greater than \$1 million through the earlier identification of cyber threats through the implemented control measure. In addition, control measures such as API key management and advanced e-mail security directly address high-risk threat areas identified during the risk assessment, thereby providing substantial financial and operational advantages.

12.4 Conclusion of CBA

Therefore, as determined through the analysis conducted above, all of the proposed controls are financially justified and required. Therefore, Meridian FinTech Solutions should provide priority status to investments in high-impact control measures. High-impact control measures include those designed to mitigate critical risks such as unauthorized access, cyber-attacks, and service availability. This cost-benefit methodology

provides for the efficient allocation of organizational resources while increasing the overall security posture, compliance posture, and resiliency of Meridian FinTech Solutions.

13. Implement schedule

The Risk Management Plan (RMP) Implementation Schedule is presented in Appendix D. It defines the Phases, Activities, Timelines, and Resources necessary to accomplish the risk management process for Meridian FinTech Solutions. The RMP Implementation Schedule includes all the phases of the Risk Assessment Process, Mitigation, Business Impact Analysis (BIA); and Business Continuity Planning (BCP). This will enable an efficient and orderly execution of each activity.

14. Business Impact Analysis

A business impact analysis (BIA) is an evaluation by Meridian FinTech Solutions of the possible impacts on their business operations in response to a disruption of one or more of their most important business activities. The BIA will identify which business processes are the most important to Meridian's operation, determine what type of impact could be experienced with an interruption in those business processes, and define what time frame would be acceptable to restore those business processes to normal operation so that Meridian can continue operating.

14.1 Critical Business Functions

Business activities that are considered critical to Meridian include: 1- **Payment processing (Meridian Pay-API)**: This activity provides financial transaction services to approximately 50,000+ customers. 2- **Fraud Detection (fraud-shield)**: This activity uses real-time monitoring and analytical techniques to detect risk associated with financial transactions. 3- **Financial reporting (fin-report)**: This activity supports regulatory requirements and anti-money laundering (AML) reporting obligations. 4- **Cloud Infrastructure Operations (AWS/GCP)**: This activity ensures that Meridian has hosted services and

service availability to its users. 5- **Customer Account/Wallet Services (wallet-Link)**: This activity allows customers of Meridian to engage in financial transactions.

14.2 Critical Resources

Resources that are required to allow Meridian to **perform critical business activities include**: 1- Cloud infrastructure (AWS and GCP), 2- Golden Record database, 3- APIs/application services, 4- Employee access systems/endpoints, 5- Network connectivity/cloud services, 6- Financial/customer Data

14.3 Potential Impacts from Disruptions

Potential negative impacts on Meridian from **Disruptions to critical systems/resources include**: 1 - Loss of revenue from failed transactions, 2- Damage to the company's reputation/customer trust, 3- Regulatory penalties/non-compliance issues, 4- Downtime impacting Meridian's ability to serve its international client base, 5- Data loss/Data corruption.

14.4 Recovery Objectives

The Recovery Objectives (ROs) in Appendix E identify how long it is reasonable to have a service unavailable when a failure occurs and what needs to be done by Meridian Fintech in order to restore the functionality of its critical IT systems.

14.5 BIA Summary

The analysis shows that Meridian FinTech Solutions operates in an extremely time-sensitive environment. Small delays in operations can cause large monetary losses along with interruptions in business. Payment processing and fraud prevention is critical to the company's ability to continue offering its services and meeting customer expectations. MAO, RTO, and RPO established during the analysis will help define the goals of recovery efforts within the Business Continuity Plan (BCP) to assist in providing adequate resources and solutions.

15. Business continuity plan (BCP)

A Business Continuity Plan (BCP), in essence, will allow Meridian FinTech Solutions to operate at an acceptable level, even when faced with some form of significant operational interruption. As part of this effort, we will focus our efforts toward keeping all systems available by limiting the time spent on Downtime and ensuring customer service continues uninterrupted.

15.1 Continuity Strategy

Meridian has adopted a Multi-Cloud Continuity Strategy to provide the best opportunity to achieve High Availability and Resilience. We will utilize both the cloud infrastructures provided by Amazon Web Services (AWS) and Google Cloud Platform (GCP). This will enable us to provide Redundancy & Failover capability. **Our key strategies consist of** 1- **Cloud Failover** – automatically switching from AWS to GCP for Critical Services such as Fraud-Shield. 2- **Redundancy** – Deploying Systems across Multiple Availability Zones to decrease Single Points of Failure. 3- **Load Balancing** – distributing the Traffic to keep Systems Stable & Performing.

15.2 Backups and Data Recovery

Meridian protects critical data through the following backup methods:

Automated Regular Back-ups of the Golden Record Database; Data Replication either Real-Time or Near Real-Time across Regions of the Cloud; Backup Data Securely Stored in Geographically Separate Locations; Verify Integrity of Backup Data Periodically. All of these measures will help to restore critical data in the shortest amount of time possible should it become lost or corrupted.

15.3 Incident Response and Recovery

If a disruption occurs, the following actions will take place: **Detection and Identification** – Identify the Disruption through Monitoring Tools; **Containment** – Reduce the Impact of the Disruption; **Recovery** – Return Affected Systems through Back-ups or Fail-over Mechanisms; **Verification** – Verify that All

Systems are Functioning Normally; **Communication** – Notify Stakeholders & Customers When Necessary.

15.4 Communication Plan

An effective Communication Plan will assist in providing timely notification to all parties involved. **The plan includes** Internal Notification to IT, Management, & Security Teams; Customer Notification Regarding Service Status; Notification to Regulatory Authorities when Required; Using Approved Channels for Communications to Avoid Misinformation.

15.5 BCP Roles and Responsibilities

The following Teams have specific roles and responsibilities in executing the BCP: 1- **IT & Security Teams** – execute Recovery Procedures to return systems, 2- **Management** – make Strategic Decisions to Coordinate Response Efforts, 3- **Communications Team** – Internal and External Communications, 4- **Employees** – follow Instructions and Report Issues Timely.

15.6 BCP Testing and Maintenance

In order for the BCP to remain Effective, it Must Be Tested and Updated On A Regular Basis: 1- **Methods Used for Testing** – Simulation Exercises, Fail-over Testing, Disaster Recovery Drills 2- **How Often to Test** – minimum Annually, or Following Major System Changes 3- **Assessing Results** – Identify Weaknesses and Improve Response Procedures 4- **Test results** will assure that Meridian Fintech Solutions is able to respond to a disruption appropriately to continue operation while maintaining business continuity.

16. Monitoring and review

Risk management at Meridian FinTech Solutions is an ongoing process requiring continued monitoring and assessment to maintain relevance and effectiveness. Ongoing risk monitoring processes will continually assess all risks associated with each process and function within the company; ensure that all identified risks have been mitigated appropriately; and provide for early identification of new and emerging risks.

16.1. Continuous Monitoring

The company shall continue to monitor all aspects of our systems, networks, and cloud-based platforms to recognize potential security-related incidents, as well as newly recognized vulnerabilities. As part of this effort, we will utilize the following methods to **continuously monitor the systems and networks**: 1- **Real-time monitoring** of all system activity and security event occurrences. 2- **Collection of logs** and analysis of log data across both AWS and GCP cloud-based computing environments. 3- **Utilization of centrally managed** monitoring solutions (i.e., Security Information and Event Management (SIEM) System). 4- **Identification of unauthorized access**, anomalies, and/or suspicious user behavior.

16.2. Periodic Review and reassessment of Risks

All identified risks will be evaluated at least annually to determine whether the current risk management strategy continues to meet the changing needs of the company. **The evaluation will include**: 1- Regularly evaluating existing risks based on current trends in the threat landscape. 2- Evaluating the effectiveness of existing controls. 3- Updating risk ratings based upon new information, actual incidents, etc. 4- Identifying additional emerging threats/vulnerabilities.

16.3. Audit and Compliance Review

Regular audit reviews will be performed by Meridian FinTech Solutions to verify that we are meeting both internal policy requirements, as well as external regulatory requirements (i.e., PCI DSS, GDPR, AML). Audits will provide Meridian FinTech Solutions with the opportunity to identify vulnerabilities in their security controls that could be exposed through audits and to ensure that they continue to comply with established industry standards.

16.4. Plan Maintenance/Updates

Meridian FinTech Solutions' Risk Management Plan will be **updated at least semiannually to account for**: 1- Changes in the way we conduct business or utilize technology, 2- New systems/services being

introduced into our infrastructure, 3- Results of audits/tests/incident reports, 4- Feedback received from our stakeholders and management.

16.5. Monitoring Summary

Periodic assessments and ongoing monitoring of systems help Meridian FinTech Solutions keep up with changing threats and have a strong security posture. The proactive process we use for monitoring and assessment helps build the long-term operational stability needed for compliance and overall system stability.

17. Conclusion

In summary, Meridian FinTech Solutions faces various risks due to cloud computing technology and financial data involved in the organization. There are many risk factors facing the company, as well as their implications for the company. The implementation of an efficient risk management process, such as risk assessment, mitigation strategies, BIA, and BCP, can enable the firm to create an appropriate risk profile and manage the risks accordingly. Implementation of these strategies, such as better BYOD policies, tighter access control, and monitoring systems consolidation, will minimize risks faced by the company. Risk Monitoring and Evaluation should be conducted frequently in order to keep the risk management process updated. In general, an efficient risk management process will ensure the company has adequate security measures and achieves success.

18. Appendices

Appendix A Table 10.1: Qualitative Risk Assessment Summary for Meridian FinTech Solutions

The purpose of this section is to present a fully qualified quantitative risk assessment table that includes all the identified risks along with associated asset(s), threat(s), and vulnerability(s), the likelihood of occurrence of each risk, and its impact on the business, and a risk rating and an assigned priority based upon those assessments. All of the information included within this section supports the conclusions drawn in the body of this document and will serve as a point of reference for further risk analysis and/or making decisions regarding security control implementation.

#	Asset	Threat	Vulnerability	Likelihood	Impact	Risk Level	Priority
1	Wallet-Link / APIs	Unauthorized access (ex-employee)	Hard-coded API key	High	High	High	Critical
2	Financial Systems	Business Email Compromise (BEC)	Weak email security controls	High	High	High	Critical
3	Cloud Infrastructure (AWS/GCP)	Cyberattack / intrusion	Lack of centralized SIEM	High	High	High	Critical
4	Customer Data	Data breach	Shadow IT (unsecured communication)	Medium	High	High	High
5	Employee Devices	Malware / data leakage	Weak BYOD controls	Medium	Medium	Medium	Medium
6	Cloud Services	Service outage	Full cloud dependency	Medium	High	High	High
7	Systems Access	Unauthorized access	Poor access control management	Medium	High	High	High

8	Compliance Data	Regulatory violations	Weak compliance monitoring	Low	High	Medium	Medium
---	-----------------	-----------------------	----------------------------	-----	------	--------	--------

Appendix B Table 11.1: Risk Mitigation Plan for Meridian FinTech Solutions

This Risk Mitigation Plan will provide a comprehensive set of controls and corrective actions to lower the probability and potential impact of the risks we have identified. Recommended measures for this plan were established using recognized “best in class” standards from our industry, as well as specific to Meridian FinTech Solutions' cloud-based environment and operations. In order to prioritize the most significant risks we have identified, the plan assigns responsibilities, defines timeframes for implementation, and estimates costs associated with each control measure so that they can be executed in a practical manner. Ultimately, through the application of these controls, we aim to enhance our overall level of security, improve the resiliency of our systems, and ultimately reduce the residual risk to an acceptable level.

#	Risk	Recommended Control	Description	Responsible Party	Timeline	Cost Level	Residual Risk
1	Unauthorized access (API key)	Secure API key management	Remove hard-coded keys, implement secrets management and key rotation	DevOps & Security Team	Short-term	Medium	Low
2	Business Email Compromise (BEC)	Advanced email security	Implement email filtering, anti-phishing tools, and employee awareness training	IT & Security Team	Short-term	Medium	Low

3	Lack of SIEM	SIEM implementation	Deploy centralized logging and monitoring system across AWS and GCP	Security Team	Medium-term	High	Medium
4	Data leakage (Shadow IT)	Enforce communication policies	Restrict unauthorized apps, implement approved communication tools	Management & IT	Short-term	Low	Medium
5	BYOD risks	Mobile Device Management (MDM)	Enforce security controls on personal devices (encryption, remote wipe)	IT Team	Medium-term	Medium	Low
6	Cloud service outage	Multi-cloud failover strategy	Enhance redundancy between AWS and GCP systems	DevOps Team	Medium-term	High	Low
7	Unauthorized system access	Access control improvement	Implement role-based access control (RBAC) and periodic access reviews	IT & HR	Short-term	Low	Low
8	Compliance violations	Compliance monitoring	Implement regular audits and compliance	Compliance Team	Medium-term	Medium	Low

			tracking systems				
--	--	--	------------------	--	--	--	--

Appendix C Table 12.2 Cost-benefit evaluation

Beginning with Appendix C, the full analysis of the costs and benefits for major security controls will be presented. The costs to implement these controls are compared to potential loss savings, and a comparison of the net cost/benefit is provided. The purpose of this data collection effort is to support decisions that may need to be made, as well as prioritize future investment in security systems.

Control	Estimated Cost	Potential Loss Avoided	Net Benefit
SIEM Implementation	\$150,000	\$1,000,000+ (breach detection/prevention)	High (Cost << Benefit)
API Key Management (Secrets Manager)	\$50,000	\$500,000+ (unauthorized access)	High (Cost << Benefit)
Advanced Email Security	\$40,000	\$500,000–\$1,000,000 (BEC prevention)	High (Cost << Benefit)
Mobile Device Management (MDM)	\$30,000	\$200,000+ (data leakage prevention)	Moderate (Cost < Benefit)
Cloud Failover Enhancement	\$200,000	\$20,000–\$50,000 per hour downtime avoided	High (Cost << Benefit)
Compliance Monitoring Tools	\$60,000	\$500,000+ (fines and penalties)	High (Cost << Benefit)

Appendix D Table 13: Risk Management Plan Implementation Schedule for Meridian FinTech Solutions

Appendix D represents the detailed implementation plan for the Risk Management Plan. The table provides all the Phases of the Project, the Activities related to each Phase, Responsible Parties for Each Activity, Durations of Each Activity, Start Dates & End Dates, and Required Resources for Each Activity. The RMP Implementation Schedule is intended as a working document to assist in executing and managing the Risk Management Process.

Phase	Activity	Description	Responsible Party	Duration	Start Date	End Date	Resources
Phase 1	Project Initiation & Planning	Define scope, objectives, stakeholders, and risk management methodology (NIST-based)	Project Manager & Risk Team	1 week	Mar 25	Mar 31	Project plan, NIST guidelines, documentation tools
Phase 2	Asset Identification	Identify critical assets (AWS, GCP, APIs, financial data, infrastructure)	IT & Security Team	1 week	Apr 1	Apr 7	Asset inventory tools, cloud dashboards
Phase 3	Threat & Vulnerability Analysis	Identify threats (BEC, cyberattacks) and vulnerabilities (API keys, Shadow IT, no SIEM)	Security Team	1 week	Apr 8	Apr 14	Security reports, logs, threat intelligence tools
Phase 4	Risk Assessment	Evaluate risks using likelihood and impact (risk matrix)	Risk Management Team	1 week	Apr 15	Apr 21	Risk matrix, assessment tools

Phase 5	Control Assessment	Evaluate existing controls (MFA, monitoring gaps, missing SIEM)	IT & Security Team	1 week	Apr 22	Apr 28	Security tools, audit reports
Phase 6	Risk Mitigation Planning	Define mitigation strategies (SIEM, API security, email protection, MDM)	Management & IT	1 week	Apr 29	May 5	Risk frameworks, policy documents
Phase 7	Control Selection & Design	Select and design appropriate controls for implementation	Security Team	1 week	May 6	May 12	Security solutions, vendor tools
Phase 8	Implementation Planning	Plan deployment steps, allocate resources, assign responsibilities	Project Manager	1 week	May 13	May 19	Project planning tools
Phase 9	Risk Mitigation Implementation	Deploy controls (SIEM, API security, email security, MDM systems)	IT & Security Teams	2 weeks	May 20	Jun 2	SIEM tools, API security tools, MDM systems
Phase 10	Business Impact Analysis (BIA)	Identify critical functions, MAO, RTO, RPO, and impact of disruptions	Risk Team	1 week	Jun 3	Jun 9	Financial data, analysis tools
Phase 11	Business Continuity Planning (BCP)	Develop recovery strategies, failover plans, and continuity procedures	Management & IT	1 week	Jun 10	Jun 16	Backup systems, cloud failover tools

Phase 12	Testing & Validation	Test controls, disaster recovery, and failover mechanisms	IT & Security Teams	1 week	Jun 17	Jun 23	Testing tools, simulation environments
Phase 13	Final Reporting	Document final RMP, findings, and recommendations	Project Team	1 week	Jun 24	Jun 30	Documentation tools
Phase 14	Monitoring & Review	Continuous monitoring of risks and system performance	Security Team	Ongoing	Jul 1	Ongoing	SIEM dashboards, monitoring tools
Phase 15	Continuous Improvement	Update plan, improve controls, and adapt to new threats	Risk Manager	Ongoing	Jul 1	Ongoing	Audit reports, feedback tools

Appendix E Table 14.4: Recovery Objectives

Recovery Objectives and Recovery Metrics are outlined in Appendix E for key business processes (MAO, RTO & RPO). The objectives outline the level at which an organization can continue to operate during a disaster. The recovery metrics will assist with determining what recovery process should be a priority, as well as supporting the development of business continuity plans.

Business Function	MAO (Maximum Acceptable Outage)	RTO (Recovery Time Objective)	RPO (Recovery Point Objective)
Payment Processing (Pay-API)	1 hour	30 minutes	Near real-time
Fraud Detection (Fraud-Shield)	1 hour	30 minutes	Near real-time
Financial Reporting (Fin-Report)	4 hours	2 hours	1 hour
Wallet Services (Wallet-Link)	2 hours	1 hour	30 minutes
Cloud Infrastructure	1 hour	30 minutes	Near real-time